

01 Software Security

Secure Software Development

Jonathan Knudsen

shellhammer@duke.edu



The Holy Trinity

- Confidentiality
- Integrity
- Availability

Some Others

- Authentication
- Authorization
- Nonrepudiation

(Not *that* CIA)

Security is Like Cleaning or Safety

- You never get to 100%
- "Is it secure?" is not a meaningful question
 - No: "Is the kitchen counter clean?"
 - Better: "How did you disinfect the kitchen counter?"
 - No: "Is this car safe?"
 - Better: "If I add a collision detection system, will fewer people die?"
- Your software can be *more* secure or *less* secure
- There are no absolutes
 - Sorry
- This is really risk management

Balance

- Value of assets
- Cost of compromise

What's the Big Deal?

- Software is everywhere
 - Marc Andreessen: "Software is eating the world."
 - Watts Humphrey: "Every business is a software business."
- Most software is not made right
- Rewards are high
- Attacker costs are low

Vulnerabilities: Three Flavors

- In software, a *vulnerability* is a weakness that could be exploited by an attacker to damage C, I, or A
- **Design** vulnerabilities
 - Bank web site with no authentication
- **Configuration** vulnerabilities
 - Bank web site where all users get the same default password
- **Code** vulnerabilities
 - Mistake in the web site code so an attacker can supply input that causes a failure
- I use "vulnerability" and "bug" interchangeably, but some people are more pedantic about it (another common term: *weakness*)

Known Vulnerabilities

- Vulnerabilities that have been found and published
- In the US, NIST keeps a list of known vulnerabilities
 - National Vulnerability Database (NVD)
 - <https://nvd.nist.gov/>
- Each vulnerability is known as a CVE
 - It stands for Common Vulnerabilities and Exposures
- In general...update your software!
 - But it's painful
 - And people frequently don't (cough, Equifax)

Unknown Vulnerabilities

- You've already made a mistake, but no one has found it yet
- Also called *zero days* or *0days*
- Attackers love these

Reactive Security

Band-Aids Don't Fix Bullet Holes

- Basically most of the security industry
 - Bajillions of dollars every year
- Antivirus, for example
- Firewalls
- IDS / IPS
- Malware or attack "signatures"



Thanks T-Swizzle

Proactive Security

Break Your Own Stuff First

- More testing and better testing
- Before you release software, find more bugs and fix them
- Slightly flawed analogy: crash testing for cars
- Variety of approaches
 - Design review
 - Code review
 - Pair programming
 - Penetration testing (pentesting)
 - Automation!

Perimeter Security



- Comforting and persistent analogy, but hokum
- Some things are obviously wrong, but otherwise...
 - What about new kinds of attacks?
 - What about attacks that are clever enough to change?
- Firewalls, IDS / IPS work this way

Product Security and IT Security

- Organizationally, companies usually keep these separate

IT Security

- Information Technology (IT)

Pain in the *AST

Some Common Terminology

- Static Application Security Testing (SAST)
 - This includes source analysis tools
- Dynamic Application Security Testing (DAST)
 - This includes fuzzing

Pain in the *AST

Some Common Terminology

- Static Application Security Testing (SAST)
 - This includes source analysis tools
- Dynamic Application Security Testing (DAST)
 - This includes fuzzing
- And less common...
- Mobile Application Security Testing (MAST)
- Interactive Application Security Testing (IAST)

Workshop

Create a Padded Room

Goals

- Give you a safe place to break things
- Avoid messing up your computer
- Learn about virtualization
- Learn some Linux system administration

Virtualization

- Run a computer (a virtual machine or VM) inside your computer
- Try out different operating systems in VMs
- Install software and configure your VM without messing up your host OS

VirtualBox

- Free
- Easy
- I'm told it's not a "real" virtualization solution
 - This is the one I know
- Use other virtualization if you must: KVM, VMware, etc.
- Download and install

Linux

- Linux comes in a million different flavors (called "distributions" or "distros")
- Pick something easy and well-supported
 - Ubuntu
 - Linux Mint
- Get an installer `.iso` (a virtual optical disk)

Run VirtualBox

- fixme: steps to create new VM

Install Guest Additions

- Useful for shared folders, shared clipboard
 - Without this, getting things in and out of the VM is hard

Getting Started with Linux

- Open a terminal window (Ctrl-Alt T sometimes works)

```
sudo apt-get update
```